

Plaid Security Questionnaire Answer Guide

OWNER REVIEW

Do not submit yet: the production edge still accepts TLS 1.1 and several answers require owner verification.

Prepared: 2026-08-13 Scope: Vanteloq production application and the Plaid questionnaire currently shown in the Plaid Dashboard.

Important submission rule

Answer only for controls that are both implemented and operating. A policy document describes the required program; it becomes adopted only after the owner signs it and begins retaining review evidence. Do not check an answer because it sounds desirable.

Immediate corrections

- 1 Correct the saved contact email from hussienissa@lexdgeconsulting.com to hussienissa@lexedgeconsulting.com.
- 2 Enter the phone as +1 780-716-6219.
- 3 Use security@vanteloq.com only after that mailbox or forwarding rule is created, monitored, and tested.
- 4 Replace the saved privacy answer that says the policy “will be published when we go live.” Vanteloq is live and the policy is published at <https://vanteloq.com/privacy>.
- 5 Do not submit the questionnaire until the TLS 1.1 edge acceptance is removed or Plaid confirms in writing that the deployment meets its requirement.

1. Security governance

Contact

Recommended entry

Hussien Issa — Owner and Security Lead
Email: hussienissa@lexedgeconsulting.com
Phone: +1 780-716-6219

Documented policy and operational program

Current safe answer: Yes - We have an operational information security program, but no documented policy or procedures until the attached Information Security Policy is signed and its review calendar is established.

After owner adoption: select Yes - We have a documented policy, procedures, and an operational information security program that is continuously matured only after:

- the approval page is signed and dated;
- the first quarterly control review is scheduled;
- a risk register and exception register are created; and
- the adopted PDF is uploaded.

Upload: Vanteloq-Information-Security-Policy.pdf after approval.

2. Access control and authentication

Access controls for production assets and sensitive data

Select now where the answer is about the Vanteloq application:

- Role-based access control (RBAC)
- Use of OAuth tokens or TLS certificates for non-human authentication

Select after policy adoption and evidence exists:

- A defined and documented access control policy is in place
- Periodic access reviews and audits are performed — only after the first dated review

Do not select without separate operational proof:

- automated de-provisioning for terminated or transferred employees;
- zero trust access architecture; or
- centralized identity and access management for all production administration.

Application evidence: Supabase token verification, immutable subject binding, active organization membership, server-side roles and permissions, tenant isolation, AAL2 enforcement, same-origin checks, and rate limiting.

MFA before a consumer connects an account through Plaid Link

Answer: Yes - Non-phishing-resistant multi-factor authentication is performed.

Vanteloq uses Supabase TOTP and requires an AAL2 session before protected Plaid Link actions. TOTP is MFA, but it is not phishing-resistant. Do not select the phishing-resistant answer unless Vanteloq deploys and enforces passkeys, security keys, or another phishing-resistant factor.

Screenshot evidence: use the normal six-digit authenticator challenge and successful verified-session screen. Never upload a QR enrollment screen, recovery code, shared secret, token, browser storage, or developer console.

MFA for critical systems that store or process financial data

Conditional answer: select the non-phishing-resistant MFA answer only after confirming MFA is enabled for every applicable Cloudflare, Supabase, Plaid, source-control, and production-email administrator. If even one critical administrator can use password-only access, answer No and remediate it first.

Maintain an administrator MFA register with provider, account owner, factor type, verification date, and reviewer. Do not store recovery secrets in the register.

3. Network and data encryption

TLS 1.2 or better in transit

Current answer: No.

An independent check on 2026-08-13 showed that <https://vanteloq.com> supports TLS 1.2 but also accepts a TLS 1.1 handshake. HSTS does not correct that minimum-version gap. Remediate the Cloudflare custom-domain edge and rerun both a TLS 1.1 rejection test and a TLS 1.2 success test before changing this answer to Yes.

Plaid consumer data encrypted at rest

Answer: Yes - We encrypt ALL consumer data retrieved from the Plaid API at-rest.

Evidence: Cloudflare D1 encrypts stored database objects at rest, and Vanteloq applies an additional AES-256-GCM envelope to stored Plaid credentials. Keys remain in server-side environment configuration and are not returned to the browser.

4. Development and vulnerability management

Current safe selection

- We actively monitor and address end-of-life (EOL) software in use

Select only after the new policy is adopted and operating evidence exists

- We patch identified vulnerabilities within a defined SLA — the Information Security Policy defines 24-hour critical, 7-day high, 30-day medium, and 90-day low targets; select this only after findings are tracked against those dates.

Do not select yet

- We actively perform vulnerability scans against all employee and contractor machines, production assets

The repository has dependency audits and security tests, but that is not evidence of managed scanning on every employee/contractor endpoint and every production asset. Add a managed endpoint and external production scanning program before selecting it.

5. Privacy and consumer data rights

Published privacy policy

Answer: select the option stating that a privacy policy is published where Plaid Link is deployed. **URL:**

<https://vanteloq.com/privacy>

Verify the public URL from a signed-out browser and preserve a dated screenshot/PDF. The policy covers Plaid categories, purposes, consent, providers, transfer, retention, deletion, security, and consumer requests.

Consumer consent

Answer: Yes.

Vanteloq records affirmative, versioned consent before generating a Plaid Link token. It binds the consent to the authenticated subject, organization, purpose, data categories, and policy versions, and requires freshness before token exchange.

Data retention and deletion policy

Current safe answer: Yes only after the owner signs the Data Retention and Disposal Policy and schedules the quarterly enforcement review.

The product already has an owner-only, AAL2-protected Plaid deletion workflow that deletes credentials, accounts, transactions, balances, derived cash data, and sync state, while keeping only de-identified audit evidence. Policy adoption converts the documented schedule into an accountable operating requirement.

Upload: Vanteloq-Data-Retention-and-Disposal-Policy.pdf after approval.

Attestation

Check Plaid's remediation attestation only if you intend to track and remediate disclosed gaps. It does not turn an unsupported Yes into a correct answer. Record the TLS minimum-version gap, endpoint-scanning gap, critical-admin MFA verification, first access review, and first retention review in the action register.

Evidence register

Questionnaire area	Primary evidence
Governance	Signed Information Security Policy; approval record; CONTROL_EVIDENCE_AND_RISK_REGISTER.md; quarterly review record
RBAC and AAL2	server/authorization.ts, server/api.ts, Supabase MFA configuration, authentication tests
Plaid consent and deletion	Plaid link-token, exchange, privacy-control, and delete-data routes; privacy and Plaid tests
At-rest encryption	server/integrations/plaid.ts; Cloudflare D1 data-security documentation; key-management evidence
TLS	Dated TLS 1.1 rejection and TLS 1.2 success output after remediation
Vulnerability management	Signed policy, dependency reports, EOL review, findings register, endpoint/external scan reports when deployed
Privacy	Public privacy URL, dated screenshot, policy version, consent record
Retention	Signed retention policy, quarterly review, deletion audit sample, provider revocation evidence

Open action register

ID	Required action	Owner	Due	Status
PLAID-01	Correct the questionnaire contact email	Hussien Issa	Before submission	Open
PLAID-02	Approve and sign both policies	Hussien Issa	Before strongest governance/retention answers	Open
PLAID-03	Remove TLS 1.1 acceptance at the production edge and retest	Hussien Issa	Before submission	Open blocker
PLAID-04	Verify MFA on every critical administrative account	Hussien Issa	Before answering critical-system MFA	Open
PLAID-05	Complete and retain the first access and retention reviews	Hussien Issa	Within 90 days of adoption	Open
PLAID-06	Deploy and evidence endpoint and external production vulnerability scanning	Hussien Issa	Before selecting comprehensive scanning	Open